



Elementos clave para la gestión de ciberseguridad a nivel ejecutivo



El Departamento de Seguridad Nacional de los Estados Unidos de Norteamérica describió también los conceptos clave para la gestión de ciberseguridad a un nivel ejecutivo (s.f.).



En el mismo documento que vimos en el recurso anterior, el Departamento de Seguridad Nacional (DHS, s.f.) describió los elementos clave para la gestión de ciberseguridad a un nivel ejecutivo. Son ocho elementos clave, los cuales enlistamos a continuación:

1 Incorporar el ciberriesgo en la gestión de riesgos y los procesos de gobierno corporativo

La ciberseguridad no es implementar una lista de requerimientos, se trata más bien de **gestionar los ciberriesgos en un nivel aceptable**. Gestionar los riesgos de ciberseguridad como parte de la gestión integral de riesgos, gobierno corporativo y continuidad de negocio provee un **marco de trabajo estratégico** para manejar los riesgos a nivel organizacional.

2 Escalar las discusiones de gestión de ciberriesgos a la alta dirección

El involucramiento activo de la alta dirección para definir la estrategia de riesgos y su nivel aceptable permite una **gestión del riesgo más eficiente en costos** y, además, **alineada con las necesidades de negocio de la organización**. La comunicación regular entre la dirección y el equipo responsable de esa gestión **facilita la concientización de los riesgos actuales** que afectan a la organización y sus impactos al negocio.



3 Implementar estándares de la industria y mejores prácticas, no depender en cumplimiento

Un programa de ciberseguridad integral se apoya en **estándares de la industria y mejores prácticas** para proteger sistemas y detectar problemas potenciales, además de establecer los procesos para informar las amenazas y habilitar una respuesta eficaz. Los **requerimientos de cumplimiento** ayudan a **establecer una línea base** para manejar vulnerabilidades conocidas, pero no manejan adecuadamente amenazas nuevas o dinámicas ni adversarios sofisticados. Utilizar un **enfoque basado en riesgo para aplicar estándares y prácticas de ciberseguridad** permite una **gestión más integral y eficiente** en costo que utilizar solamente actividades de cumplimiento.

4 Evaluar y gestionar los ciberriesgos específicos de la organización

Identificar los activos críticos y sus impactos asociados a ciberamenazas es prioritario para entender la **exposición específica** al riesgo de la organización: sean impactos financieros, competitivos, reputacionales o regulatorios. Los resultados de la valoración de los impactos son clave para identificar e implementar **medidas de protección, asignar recursos, planear inversiones de largo plazo y desarrollar políticas y estrategias**.

5 Supervisar y revisar

Los ejecutivos son responsables de **gestionar y supervisar** la gestión de riesgos de la organización. **Las actividades de supervisión** incluyen la evaluación regular de presupuestos de ciberseguridad, planes de adquisición de tecnologías informáticas, *outsourcing* de servicios de tecnologías de información, servicios de nube, reportes de incidentes, validaciones de riesgos y políticas de alto nivel.



6 Desarrollar y probar planes y procedimientos de respuesta a incidentes

Incluso una organización bien defendida experimentará en algún punto un ciberincidente. Cuando las defensas sean vulneradas, la alta dirección debe estar preparada para responder “**¿cuál es nuestro plan B?**” Tener planes de respuesta documentados que se ejecutan de manera regular permite asegurar **respuestas eficaces y minimizar los impactos**.

7 Coordinar la planificación de respuesta a ciber incidentes

Acciones rápidas y tempranas pueden **limitar** e, incluso, **prevenir daños**. Un componente clave en la preparación de respuesta a incidentes es la **planificación en conjunto** con la dirección de informática de la organización, los líderes de negocio, los operadores de sistema, los asesores generales y el departamento de relaciones públicas. Esto incluye integrar las políticas y procedimientos de respuesta a incidentes con planes existentes de recuperación de desastres.

8 Mantener conciencia situacional de las ciberamenazas

La conciencia situacional de la organización sobre el ambiente actual de ciberriesgos involucra la detección oportuna de incidentes, junto con el conocimiento de amenazas y vulnerabilidades específicas a la organización y su impacto de negocio.



Con este enfoque desde el nivel directivo, **la ciberseguridad pasa de ser un área solamente técnica a convertirse en parte integral de la estrategia general de la organización**, a través de la gestión de ciberriesgos y el involucramiento directo de la dirección en el establecimiento de políticas, procedimientos y controles.

Ahora te mostramos un ejemplo de la importancia de la ciberseguridad.

Objetivo

Aplicar la Tríada de Ciberseguridad (CIA) y la gestión de riesgos ejecutiva para proteger la continuidad del negocio, superando la visión limitada de seguridad como solo "confidencialidad".

Problemática común

"Nos hackearon y no perdimos datos, pero la fábrica estuvo parada una semana".

Una empresa de manufactura invierte fuertemente en encriptación para proteger sus patentes (confidencialidad). Sin embargo, descuidan los sistemas de respaldo y la redundancia de sus servidores de control de producción. Un ataque de Ransomware cifró los servidores operativos. Aunque los atacantes no robaron datos, la empresa no puede producir.

La pérdida millonaria se debe a una falla en la **disponibilidad**, un aspecto de la tríada CIA que la dirección subestimó al ver la seguridad solo como "evitar fugas de información".

Solución desde la información de la lección

1. Aplicación Integral de la Tríada CIA:

Confidencialidad: Controles de acceso.

Integridad: Auditorías y *checksums* para asegurar que las órdenes de producción no se alteren.

Disponibilidad: Implementar planes de recuperación ante desastres (DRP) y continuidad de negocio (BCP), asegurando que la operación pueda restaurarse rápidamente.

2. Gestión de riesgos ejecutiva: El liderazgo debe realizar un inventario de activos (incluyendo intangibles como la reputación) y asignar recursos para **mitigar** riesgos de disponibilidad (ej. servidores redundantes) o **transferirlos** (ej.: ciberseguros).

3. Cultura de seguridad: Involucrar a todos los empleados como la primera línea de defensa, liderando con el ejemplo desde la alta dirección para priorizar la seguridad en los procesos diarios.

Errores comunes que deben evitarse

1. Ver la ciberseguridad como un problema de TI: Es un problema de gestión de riesgos empresariales que requiere supervisión del consejo directivo.

2. Enfoque solo en cumplimiento: Cumplir con una norma no garantiza seguridad ante amenazas dinámicas. Se debe adoptar un enfoque basado en riesgos específicos de la organización.

3. Descuidar la disponibilidad e integridad: Centrarse solo en prevenir el robo de datos y olvidar que la alteración de datos o la caída de sistemas pueden ser igual de destructivas.

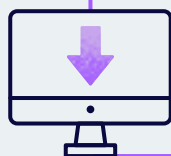
Puntos clave

- La ciberseguridad protege la confidencialidad, integridad y disponibilidad (CIA) de la información y sistemas.
- La gestión de riesgos requiere identificar activos y definir estrategias de tratamiento (aceptar, evitar, mitigar, transferir).
- El liderazgo activo es indispensable para alinear la estrategia de seguridad con la misión de la organización.

Reflexiones finales



¿El nivel ejecutivo de tu organización lleva a cabo alguno de los elementos clave vistos anteriormente?, ¿cuál consideras que podrían mejorar para gestionar mejor los ciberriesgos?



Descarga la versión impresa en el apartado de **Archivos adjuntos** de la plataforma.